TENAZ

DOCUMENTAÇÃO DO PROJETO

Histórico de versões

Tenaz · Gestão de Manutenção e Frota

Arquivo: CHANGELOG.md

Todas as implementações e correções da Tenaz são registradas neste arquivo, versão a versão.

O formato segue o Keep a Changelog 1.1.0 e as versões seguem o Versionamento Semântico 2.0.0. As regras de uso estão nos requisitos RNF-039 e RNF-040 de docs/1_ESPECIFICACAO_REQUISITOS.md.

Como registrar

- Toda mudança de comportamento entra em `[Não lançado]` no mesmo pull request que a implementa.
- Grupos: **Adicionado**, **Alterado**, **Corrigido**, **Removido**, **Obsoleto**, **Segurança**.
- Cada item descreve a mudança em linguagem de usuário e cita a referência: `RF-...` / `RNF-...` para implementação, número do chamado ou da issue para correção.
- Quebra de compatibilidade da API pública é marcada com **QUEBRA** e exige versão MAJOR.
- No release, `[Não lançado]` vira `## [X.Y.Z] - AAAA-MM-DD`, igual à tag `vX.Y.Z`.
- Entradas publicadas não são reescritas; erros são corrigidos com nota na própria entrada.

[Não lançado]

Fase de concepção. Ainda não há versão do software publicada.

Adicionado

- Nome e identidade visual da Tenaz: símbolo, logotipo, cores, tipografia, brandbook e arquivos SVG e PNG em `marca/`.
- Estudo de mercado e benchmarking de sistemas de manutenção e frota em `docs/pesquisa/`.
- Documentação do projeto em `docs/`: sumário executivo, requisitos, banco de dados, APIs, fluxos e regras de negócio, arquitetura, roadmap, padrões de design, segurança e confiabilidade.
- Módulos de terceiros e assistência técnica (TER) e de locação (LOC), estoque em poder de subcontratadas, peças serializadas e reparáveis com envio para conserto.
- Módulo de gestão de serviços do prestador (SRV, "Tenaz Serviços"): conta própria da subcontratada com cadastro de técnicos, clientes e equipamentos de clientes, OS vinculada a equipamento e técnico com serviço a realizar, componentes substituídos e horas, app do técnico e conexão com as contas de clientes que usam a Tenaz.
- Requisito de versão visível no canto inferior direito da tela principal (RNF-039) e deste histórico de versões (RNF-040).
- Ferramenta de conversão de documentos Markdown para PDF com a identidade da marca em `ferramentas/md2pdf.py`.
- Plano de execução do projeto em `docs/execucao/`: modelo de trabalho com ciclo de sete passos por etapa, catálogo de 16 agentes especializados correspondentes aos papéis do time de 15 pessoas do roadmap, catálogo de 12 skills com os procedimentos obrigatórios, e as etapas E00 a E12 do MVP com entrega, agentes, portão de saída e evidência de cada uma.
- Equipe de agentes especializados em `.claude/agents/` e skills do projeto em `.claude/skills/`, com os portões de isolamento entre empresas (RNF-013), de acesso externo (RNF-037, RNF-038), entre contas conectadas (RNF-041, RNF-042), de operação offline (RNF-010), de acessibilidade (RNF-025) e de versão visível (RNF-039) embutidos nos procedimentos.

- Pasta `docs/prompts/` com o prompt de cada etapa do MVP e o modelo, e pasta `docs/screenshots/` com a convenção de evidência visual das telas entregues.
- **Fundação técnica (etapa E00).** Primeiro código do produto: monólito modular em Go com os subcomandos `api`, `migrate`, `migrate-status`, `openapi` e `versao`; esquemas `app` e `plataforma` com os papéis de banco, as funções de contexto e de escopo, o UUID v7 e o trigger das colunas padrão; contrato OpenAPI 3.1 gerado dos tipos Go e versionado; infraestrutura local em contêiner com PostgreSQL 17 e Valkey; esteira de CI com cinco verificações; projeto da web em Vite e do app em Expo.
- Esteira de versão e histórico (RNF-039 e RNF-040): a versão vem da tag `vX.Y.Z` e é injetada no build do backend, da web e do app, nunca digitada em arquivo de código; `GET /v1/versao` devolve versão, commit curto e data do build e nada mais; produção recusa versão de pré-lançamento; o CI bloqueia o release quando a tag, o CHANGELOG e a versão embutida divergem, e recusa pull request que altere código de produto sem registrar a mudança aqui.
- Suíte de isolamento entre empresas (RNF-013), rodando a cada build e bloqueando merge e deploy: verifica a cobertura de RLS de toda tabela com `empresa_id`, a lista explícita de catálogos globais, a propriedade de todo objeto por `tenaz_dono`, a ausência de contorno de RLS nos papéis da aplicação e a ausência de privilégio amplo do papel de sincronização (RNF-041). Inclui a prova de que o detector funciona, criando de propósito uma tabela sem política e exigindo que seja acusada.
- Fila de comandos (outbox) do app de campo, com testes contra SQLite real: nenhum comando se perde por falha de rede, rejeição ou fechamento do app; reenvio não duplica; a ordem é FIFO por ordem de serviço, sem uma OS bloquear outra; comando rejeitado guarda o motivo e aparece em "Pendências de sincronização"; cenário de sete dias de campo acumulado convergindo na reconexão (RF-MOB-002, RNF-010).
- Verificador de documentação passa a rodar no CI, resolvendo a pendência aberta na etapa 008.
- **Configuração por segmento** (escopo, sumário 0.5, seção 3.7). A Tenaz se ajusta a segmentos diferentes por blocos de catálogo fechado, sem estados nem fluxos livres. No MVP: regras de condição e efeito, como "verificação metrológica vencida bloqueia o ativo até a nova verificação" (RF-ADM-016); fase de ciclo de vida do ativo, com "Em implantação" e a ação "Colocar em operação" (RF-ATV-013); campos extras na OS, como números de lacre (RF-OS-021); tipo de OS `implantacao`, fora dos indicadores de manutenção. Na Fase 2: pacotes de segmento prontos, como o de fiscalização eletrônica (RF-ADM-017); módulo PRJ de projetos de implantação com etapas, dependências, cronograma, avanço e medição de etapas para pagamento do prestador (RF-PRJ-001 a RF-PRJ-007); módulo CTR de contratos com clientes, com meta de disponibilidade, faixas de desconto, paradas por causa externa e medição mensal (RF-CTR-001 a RF-CTR-005).
- **Conta e acesso (etapa E01, em andamento).** Trilha de auditoria imutável, com quem, quando, valores antes e depois, escopo de acesso, origem e IP, gravada na mesma transação do fato e particionada por mês sem extensão externa (RF-ADM-011). Cadastros de empresa, unidade com turnos e feriados próprios, pessoa com e sem usuário, usuário com perfis e permissões avulsas (`usuario_permissao`), e os 12 perfis padrão criados com a empresa (RF-ADM-001, RF-ADM-002, RF-ADM-004, RF-ADM-005, RF-ADM-015). Autenticação por e-mail e senha com hash Argon2id, recusa de senhas comuns e vazadas por lista local, bloqueio progressivo após 5 falhas, segundo fator TOTP, MFA obrigatório configurável por empresa, sessão web com proteção CSRF, troca de empresa, convite e redefinição de senha por e-mail, e acesso do app por OAuth 2.1 com PKCE e refresh token rotativo com detecção de reuso (RF-ADM-006, RF-MOB-001, RNF-017). Casos de uso e rotas da API `/v1/auth/*`, `/oauth/*`, `/v1/empresa`, `/v1/empresas`, `/v1/unidades` (com turnos e feriados), `/v1/pessoas`, `/v1/usuarios` (com permissões avulsas), `/v1/perfis`, `/v1/permissoes` e

`/v1/eventos-auditoria`, testadas contra PostgreSQL real: 401 sem credencial, 403 sem permissão ou sem CSRF, 404 para registro de outra empresa e para perfil externo fora do seu alcance, 412 e 428 na concorrência otimista. As telas entram na sequência da etapa.

- Catálogo canônico de 116 permissões no formato `<módulo>.<ação>`, sem exceção, e matriz dos 12 perfis padrão: `os.encerrar` só em `gestor` e `planejador`, permissões sensíveis nunca concedidas a `prestador` nem a `locatario` (RF-ADM-005).
- Fundação da web: React, rotas, temas claro, escuro e Sol pelos tokens da marca, selo de versão no canto inferior direito do login e da tela principal e diálogo "Sobre" com versão da web e da API, data do build, commit e ambiente; verificação automática de acessibilidade sem violações (RNF-039, RNF-025).
- Trilha de auditoria configurável por tela (RF-ADM-011, ampliado na etapa E01, em implementação): data e hora, usuário, IP, tipo de operação e tela ou módulo em todo evento; captura de visualização, impressão e extração ligada ou desligada por tela; integridade por hash de cada evento e selo encadeado fora do banco.
- Pasta `docs/entregas/` com o registro de cada etapa entregue e consolidada (o que ficou pronto, o portão item a item com a prova e o que foi para depois): concepção e fundação técnica (E00). O fechamento de etapa passa a escrever a entrega no aceite.
- Regras de cadastro de E01: o responsável pela conta nasce com os perfis de administrador e de gestor; os turnos da unidade inicial são informados na criação, sem calendário imposto, e turnos sobrepostos são recusados; pessoa ligada a usuário ativo não é inativada e usuário não é ligado a pessoa inativa; a pessoa criada junto com um prestador herda o fornecedor dele (RF-ADM-001, RF-ADM-002, RF-ADM-015).
- Servidor de e-mail de teste (Mailpit) na infraestrutura local, para convites e redefinição de senha em desenvolvimento.

Segurança

- Credenciais de login (senhas, segredos de MFA, sessões e tokens) isoladas num papel de banco próprio, `tenaz_autenticacao`, com pool exclusivo do módulo de autenticação, e num dono próprio, `tenaz_credencial`: nem o papel da aplicação, nem os jobs, nem o papel de manutenção leem ou forjam credencial de outra empresa (ADR-011, com emenda na mesma etapa; achados ISO-E01-02 e ISO-E01-08 da revisão de isolamento). Fica registrado o risco residual ISO-E01-09: o papel de manutenção, membro do dono do esquema, ainda pode recriar tabelas; a decisão sai antes da primeira implantação em homologação.
- Usuário externo (prestador, locatário) só altera o próprio nome e telefone; o tipo de um perfil não muda depois de criado; jobs leem só a empresa do contexto; a trilha de auditoria recusa alteração, exclusão e TRUNCATE, inclusive do dono, e não aceita evento em nome de outra pessoa, com outro escopo, nem evento de login gravado fora da autenticação (achados ISO-E01-01, 03, 04, 05, 06 e 07; RNF-013, RNF-037).
- Segundo fator mais firme: o mesmo código TOTP não vale duas vezes; código errado conta no bloqueio progressivo; com o MFA obrigatório ligado pela empresa, quem não o ativou entra numa sessão que só serve para ativá-lo (RF-ADM-006).
- Usuário externo (prestador, locatário) só recebe permissão avulsa que já esteja no perfil de origem dele; liberar OS e decidir destino de peça só o administrador concede, e nunca a si mesmo (RF-ADM-005).
- Inativar um usuário revoga na hora as sessões e os refresh tokens dele naquela empresa, sem afetar as outras empresas em que ele tem acesso (RF-ADM-004).
- Armazenamento de objetos do ambiente de desenvolvimento (SeaweedFS) endurecido desde o primeiro dia: chaves JWT na API interna, que sem elas apagava um bucket com arquivo em retenção sem pedir credencial; só a porta S3 exposta; uma credencial por uso, com o mínimo de permissões; telemetria

desligada. O bucket da trilha de auditoria nasce com bloqueio de objeto em modo de conformidade e versionamento, e a tarefa `armazenamento-provar` confere, em 19 verificações, que o arquivo retido não é apagado, encurtado nem sobrescrito, nem pela credencial de administração. As imagens da infraestrutura local passam a ter versão e digest fixos (RF-ADM-011; ADR-012).

Removido

- O MinIO sai da infraestrutura de desenvolvimento; o armazenamento compatível com S3 passa a ser o SeaweedFS, open source, com bloqueio de objeto (ADR-012). Regra do projeto: só software gratuito ou open source no que o sistema usa diretamente; a hospedagem de produção na nuvem gerenciada é exceção explícita.
- Dados de saúde (ASO, exame toxicológico) saem do escopo da Tenaz por decisão do dono do produto em 2026-11-13: não há tipo de documento, campo, anexo nem permissão para eles, e a permissão `pessoa.saude.ler` deixa de existir. Uma migração nova apaga as concessões da permissão (registradas na trilha) e retira do banco a função e as restrições ligadas a ela. Quem precisa controlar ASO (NR-7) faz isso fora da Tenaz, que não alerta esses vencimentos nem os considera no despacho (sumário 0.7, seção 3.6; RF-ADM-005, RF-ADM-015, RF-CON-005, RF-FRO-001, RNF-021).

Corrigido

- Access token do app com `nbf` ("não vale antes de") no futuro passa a ser recusado; a verificação também recusa token sem `exp`, com emissor ou público errados e com cabeçalho diferente do esperado (RF-MOB-001; documento 3, seção 4.3). Defeito encontrado pelos testes pedidos na revisão de qualidade.
- Códigos de erro da API alinhados ao documento 3, que é o dono deles: o código usava MAIÚSCULAS e nomes diferentes (`NAO_ENCONTRADO`, `SEM_PERMISSAO`, `CONFLITO` com status 412) e passou a `recurso_nao_encontrado`, `permissao_negada`, `versao_desatualizada` e os demais da seção 3.2; o corpo do erro segue a seção 3.1, com `id_rastreio` e `erros[]` por campo.
- Fim de linha: `.gitattributes` fixa LF em todo arquivo de texto. Num checkout no Windows, o CRLF fazia o formato do Go e a conferência do contrato OpenAPI falharem localmente sem defeito real.
- O campo `status` do erro da API passou a inteiro de 64 bits fixos: com `int`, o contrato gerado mudava conforme a arquitetura da máquina (32 bits localmente, 64 no CI).
- A migração de base tirava o acesso ao esquema `public`, onde ficam as extensões; o tipo `citext` deixava de existir para a aplicação e o e-mail passaria a diferenciar maiúsculas. Corrigido concedendo o uso só aos papéis do sistema.
- Divergências de documentação encontradas na etapa E01: validade do refresh token do app (14 dias no documento 9, 30 em RNF-017), modelo da sessão web, tabela de permissões do documento 9 em conflito com o documento 3, nomes de campos da auditoria, situação do usuário e da pessoa entre os documentos 1 e 2, e a função `app.conferir_escopo()` do documento 2, que não compilava.
- Divergência de nomes entre os documentos 2 e 5: as funções de contexto e de escopo eram citadas no documento 5 com o esquema `tenaz` e o nome `escopo_tipo`, e no documento 2, dono do assunto, com o esquema `app` e `escopo_atual`. O documento 5 passou a usar os nomes do documento 2. Encontrada ao implementar a fundação técnica.
- Prompt inicial do projeto em `CLAUDE.md`, com as regras obrigatórias de documentação.
- Registro de etapas do projeto em `docs/etapas/`, com as etapas 001 a 008.
- Verificador de integridade e referências cruzadas da documentação em `ferramentas/verificar_docs.py` (links, IDs RF/RNF/RN/ADR, versões, registro de etapas, PDFs desatualizados).

Alterado

- Regras de acessibilidade aplicadas à marca: texto Aço sobre o laranja Sinal, contorno de foco em Aço, chip de status com texto Aço no tema claro e texto terciário em Aço 400.